

Clase 197 — Métricas y madurez del SOC

Parte: 8 — Blue Team, detección y SOC · Fuente: Blue Team Handbook — Don Murdoch 🕒 Duración estimada: 90 min · Nivel: Intermedio

Objetivo

Medir el rendimiento y la madurez de un SOC con métricas defendibles, evitando indicadores vanidosos que se pueden manipular. Aprenderás a definir KPIs de detección y respuesta (MTTD, MTTR, dwell time, cobertura ATT&CK), a evaluar la madurez con un modelo (SOC-CMM) y a comunicar el valor del SOC a la dirección.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Definir** métricas de detección y respuesta con su fórmula y fuente de datos.
- 2. **Distinguir** métricas útiles de las vanidosas o fáciles de manipular.
- 3. **Evaluar** la madurez del SOC con un modelo estructurado.
- 4. **Construir** un cuadro de mando para dirección y para el equipo.
- 5. **Usar** las métricas para priorizar mejoras (no solo reportar).

Temas

#	Tema	Por qué importa
1	Para qué medir	Mejorar, no adornar
2	MTTD, MTTR, dwell time	Núcleo del rendimiento defensivo
3	Métricas de calidad de detección	Falsos positivos, precisión, cobertura
4	Métricas vanidosas y gaming	Qué evitar
5	Cobertura ATT&CK como métrica	Profundidad vs presencia
6	SOC-CMM y madurez	Dónde estás y hacia dónde ir
7	Cuadro de mando por audiencia	Dirección vs operación
8	De la métrica a la acción	Priorizar mejoras con datos

Definiciones y características

- **MTTD (Mean Time To Detect):** tiempo medio hasta detectar un incidente. Característica: mide la eficacia de la detección; cuanto menor, mejor.
- **MTTR (Mean Time To Respond/Remediate):** tiempo hasta contener/erradicar. Característica: mide la respuesta; distingue "respond" de "remediate".

- **Dwell time:** tiempo total del atacante sin ser detectado. Característica: métrica reina; refleja el impacto real.
- **Tasa de falsos positivos:** proporción de alertas que no eran incidentes. Característica: alta = fatiga y coste; guía el afinado.
- **Cobertura ATT&CK:** técnicas detectadas frente al total relevante. Característica: mide amplitud; debe combinarse con profundidad.
- **Métrica vanidosa:** número que impresiona pero no informa (p. ej. "alertas procesadas"). Característica: incentiva el gaming, no la mejora.
- **SOC-CMM:** modelo de madurez de capacidades del SOC. Característica: evalúa personas, procesos, tecnología y servicios.

Herramientas y preparación

- Datos de tu SIEM/ticketing de laboratorio (o dataset simulado) para calcular métricas.
- Una hoja de cálculo o dashboard (Kibana/Grafana) para el cuadro de mando.
- El **SOC-CMM** (herramienta de autoevaluación gratuita) para medir madurez.
- **ATT&CK Navigator** (clase 187) para la métrica de cobertura.

No se requieren técnicas ofensivas; es una clase de gobierno y medición.

Laboratorio guiado — Cuadro de mando del SOC

1. **Elige tus KPIs.** Selecciona 6 métricas: MTTD, MTTR, dwell time, % falsos positivos, cobertura ATT&CK y % incidentes con causa raíz documentada.
2. **Define fórmula y fuente.** Para cada una, especifica cómo se calcula y de qué log/ticket sale.
3. **Calcula con datos.** Usa tus tickets/alertas de laboratorio (o un CSV simulado) para obtener valores reales.
4. **Detecta gaming.** Para cada métrica, imagina cómo un equipo podría manipularla y añade un contrapeso (p. ej. MTTR bajo + tasa de reincidencia).
5. **Mide madurez.** Completa una autoevaluación SOC-CMM en 2–3 dominios y anota tu nivel.
6. **Construye dos vistas.** Un dashboard operativo (colas, falsos positivos, cobertura) y uno ejecutivo (tendencia de dwell time, riesgo).
7. **Prioriza mejoras.** Con las métricas, define las 3 acciones de mayor impacto para el próximo trimestre.

Ejercicios

1. Escribe la fórmula y la fuente de datos de 5 métricas del SOC.
2. Identifica 3 métricas vanidosas y propón su reemplazo útil.
3. Calcula MTTD y MTTR de un conjunto de 10 incidentes de ejemplo.
4. Diseña un contrapeso para evitar el gaming de MTTR.
5. Completa una mini autoevaluación de madurez en un dominio.
6. Propón un KPI que mida la calidad de las detecciones, no solo la cantidad.

Reto verificable

Entrega un cuadro de mando con al menos 6 métricas (fórmula, fuente y valor calculado), sus contrapesos anti-gaming, y una evaluación de madurez con 3 mejoras priorizadas. **Criterio de aceptación:** cada métrica

tiene fórmula y origen de datos verificable, al menos una detecta explícitamente un intento de manipulación (contrapeso), y las mejoras priorizadas se justifican con los valores medidos, no con opiniones.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
MTTR excelente, incidentes reinciden	Se cierra sin erradicar; añade métrica de reincidencia
"Procesamos 1M de alertas"	Métrica vanidosa; reporta calidad y resultado, no volumen
Cobertura ATT&CK al 95% pero se cuelan ataques	Presencia sin profundidad; mide eficacia real de cada detección
Métricas que nadie usa	Se reportan pero no priorizan; ligá cada métrica a una decisión
Datos inconsistentes	Fuentes mal definidas; documenta fórmula y origen de cada KPI

Preguntas frecuentes

? ¿Cuál es la métrica más importante? Dwell time es la que mejor refleja el impacto real: cuánto tiempo estuvo el atacante sin ser visto. MTTD y MTTR la explican; el resto la contextualizan.

? ¿Por qué evitar métricas de volumen? Porque incentivan el comportamiento equivocado: cerrar alertas rápido o inflar cifras. Mide resultados (detectado, contenido, erradicado), no actividad.

? ¿Cómo comunico el valor del SOC a dirección? Con tendencias de riesgo y dwell time, no con jerga técnica. Muestra cómo la inversión reduce el tiempo de exposición y el impacto potencial.

Referencias

- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.
- SOC-CMM — <https://www.soc-cmm.com/>
- MITRE ATT&CK Navigator — <https://mitre-attack.github.io/attack-navigator/>
- Mandiant M-Trends (informes de dwell time) — <https://www.mandiant.com/m-trends>
- SANS, "SOC Metrics" (recursos formativos).

Siguiendo clase

Clase 198 - Casos de estudio de detección